



File No.: EXP202100318

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On July 2, 2021, the General Subdirectorate for Data Inspection (SGID) received for its assessment a notification of a personal data security breach sent by AFIANZA ASESORES, S.L with NIF B83117804 (hereinafter, AFIANZA), received on June 30, 2021, in which it informs the Spanish Agency for Data Protection of the following:

(...)

SECOND: In accordance with the provisions of Article 34.4 of the GDPR and considering that the breach affects the confidentiality of personal data (...), which may pose a high risk to the rights and freedoms of the affected individuals, on July 2, 2021, the Director orders AFIANZA to communicate the aforementioned personal data breach to the affected parties without undue delay, so that, once they are aware of it, they can take the measures they deem appropriate to avoid any risks that may affect them, in accordance with the provisions of Article 34 of the GDPR.

Furthermore, confirmation of compliance with the order to communicate to the affected parties is required within a maximum period of 30 days.

THIRD: On July 2, 2021, the Director orders the General Subdirectorate for Data Inspection to assess the need to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations.

FOURTH: By means of a document submitted on July 8, 2021, AFIANZA indicates that it has requested the ***COURT.1 to provide information regarding the security breach suffered to all individuals whose personal data appears (...).

FIFTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following details:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Date of notification of the personal data security breach (hereinafter breach): June 30, 2021, by AFIANZA ASESORES, S.L., data controller.

Date of breach detection: June 17, 2021

Date of breach initiation: June 17, 2021.

Date of breach resolution: June 17, 2021.

Method of breach detection: Employees of the responsible entity.

Confidentiality breach

Summary of the notification:

(...)

During the present actions, the following entities have been investigated:

AFIANZA ASESORES, S.L, with NIF B83117804 and address at c/ Alfonso XII, 20, 1st Floor - 28014 MADRID

The responsible entity states that, due to an error in communicating the incident, it has been reported as the name of the company AFIANZA AUDITORES, S.L., when, in reality, the name of the company is AFIANZA ASESORES, S.L. This is merely a typographical error, which only affects the name, with the NIF and address communicated in the incident of AFIANZA ASESORES, S.L. being correct.

Regarding the communication to the affected parties:

On July 2, 2021, the Director of the Spanish Agency for Data Protection signed a resolution ordering the communication of the breach to the affected parties without undue delay.

(...)

1.- Information and documentation have been requested from the notifying entity, and from the response received, the following is inferred:

(...)

SIXTH: On June 24, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate a sanctioning procedure against the accused party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified respectively in Article 83.5 of the GDPR and Article 83.4 of the GDPR.

SEVENTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/44

Public Administrations (hereinafter, LPACAP), dated July 14, 2022

AFIANZA submitted, in a timely manner, a written statement of allegations in which, in summary, it expresses the following:

I. SECURITY BREACH

AFIANZA points out that Article 4.12 of the General Data Protection Regulation (hereinafter, “GDPR”) defines a “personal data security breach” as any breach of security that results in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.

It also indicates that the Guide for the notification of personal data breaches by the AEPD establishes three types of breaches, indicating that it affects confidentiality when it results in the unauthorized or accidental disclosure of personal data, or access to it.

Next, it indicates that this Control Authority, in its Agreement to initiate sanctioning proceedings, states that AFIANZA has suffered a breach of confidentiality; that is, under the AEPD's criteria, there has been an unauthorized or accidental disclosure of personal data, or access to it.

AFIANZA states that, based on the proven and stated facts, the only certainty is that there has been a theft of a backpack, which contained not only personal documentation but also a USB with information under the control of AFIANZA as the data controller. However, a year later, there is no evidence that any third party has accessed the information contained in that USB, so the “access” or “accidental disclosure” remains mere speculation.

AFIANZA informed the AEPD of the criminal act, acting diligently and in furtherance of its proactive responsibility. In no case, neither at the time of notification nor now (a year later), has it been verified that any third party has further processed the information contained in the USB.

Therefore, it concludes that neither AFIANZA, nor the AEPD, nor any other third party has the capacity to prove that, as of today, there has been an “unauthorized access” or an “accidental disclosure” of the information contained in the USB, with only the theft of a backpack, which contained a USB, being recorded. Thus, asserting with total certainty that a breach of confidentiality has occurred is completely disproportionate in relation to the proven facts.

II. SECURITY MEASURES IMPLEMENTED BY AFIANZA

Notwithstanding the above, and in the event that this Control Authority understands that a security breach has occurred, AFIANZA wishes to highlight the security measures it has implemented, as in the Agreement to initiate sanctioning proceedings, the AEPD maintains that the identification of a security breach does not directly imply the imposition of a sanction (...), as it is necessary to analyze the diligence of those responsible and

responsible parties and the security measures applied. In this regard, AFIANZA states the following:

I. In 2018, with the direct application of the General Data Protection Regulation and subsequently with the entry into force of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, AFIANZA carried out a procedure to adapt the company to the new legal framework and implemented both technical and organizational security measures associated with each of the processing activities carried out and recorded in its Record of Processing Activities (Annex II).

II. All personnel of AFIANZA who access personal data have received training and are aware of their obligations regarding the processing of personal data (Annex III).

III. An IT Audit has been conducted in which the level of technical compliance of the personal data processing carried out under the responsibility of AFIANZA has been analyzed, verifying AFIANZA's degree of compliance with the measures and controls established by the regulations on personal data protection and associated security regulations (Annex IV).

IV. AFIANZA has implemented all possible measures to prevent unauthorized persons from accessing personal data, for this purpose:

(...)

AFIANZA points out that, as stated in Recital 83 of the GDPR, in order to maintain security and prevent breaches, the controller or processor must assess the inherent risks of the processing and apply measures to mitigate them. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation, and this is precisely what AFIANZA has been doing since the direct application of the GDPR.

AFIANZA indicates that Article 32 does not regulate a list of applicable security measures but establishes that the controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of probability and severity for the rights and freedoms of the data subjects. Therefore, basing the sanctioning argument on the lack of encryption of the stolen USB is not appropriate because

(i) it is not a mandatory security measure and

(ii) none of the security measures implemented by AFIANZA and previously communicated are taken into consideration.

In light of the above, AFIANZA understands that it processes personal data in a manner that ensures adequate security, including protection against

the unauthorized or unlawful processing and against its loss, destruction, or accidental damage, through the application of the indicated technical or organizational measures.

For the above reasons, AFIANZA asserts that it has been proven that it complies with each and every one of the principles related to processing under the GDPR, especially with the principle of confidentiality, just as it has fulfilled its obligation to implement security in each and every one of the data processing activities it carries out, indicating that this Control Authority must understand that security is not impregnable, and therefore, the regulations value the security measures adopted so that, in the event of a security incident, it has the least possible consequences. AFIANZA cannot be held responsible for having been a victim of a criminal act, just as it cannot be held responsible for a third party's breach of the implemented security measures. Likewise, the AEPD cannot guarantee or prove that there has been a violation of the rights and freedoms of third parties.

III. NOTIFICATION PERIOD FOR THE SECURITY BREACH

AFIANZA points out that Article 33 of the GDPR states that, in the event of a breach of personal data security, the data controller shall notify the competent Control Authority without undue delay and, if possible, no later than 72 hours after becoming aware of it, unless it is unlikely that the breach constitutes a risk to the rights and freedoms of natural persons. If the notification to the Control Authority does not occur within the 72-hour period, it must be accompanied by an indication of the reasons for the delay.

In this regard, AFIANZA believes it is important to remember that in the 13 days that passed from the theft of the USB until it was notified to the AEPD, AFIANZA filed the corresponding complaint and, in pursuit of its proactive responsibility, initiated an internal investigation procedure in order to ascertain and assess the possible damages arising from the theft of the backpack. (...). In addition to the above, communications were made and sent to the community of property owners regarding the criminal act. That is to say, AFIANZA maintains that it acted proactively and diligently in the days following the theft and that there was no undue delay, as the regulation expressly refers to “and if possible, no later than 72 hours,” which is not an imperative timeframe.

AFIANZA understands that the AEPD's Agreement seems to imply a criticism regarding the time that elapsed between the theft and the notification, without valuing the justification that led to the delay, nor the execution of the notification itself. Any other data controller could have chosen not to communicate the criminal act to the AEPD at all; however, AFIANZA, fulfilling its due diligence, as well as its internal Protocol, informed the AEPD as soon as it assessed the possible damage caused, and in no case did a greater risk or wider dissemination of the data occur.

AFIANZA emphasizes that, more than a year after the date of the theft, there has been no publication or any other misuse of the information contained in the USB, so the security breach for the legal purposes indicated in the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/44

has not materialized in the meantime, as has already been reported, neither AFIANZA, nor the AEPD, nor any other third party has the capacity to prove that unauthorized access to the information contained in the USB has occurred, only the theft of a backpack, which contained a USB, is recorded, which proves that the period of 13 days that elapsed from the theft to the notification has not resulted in a detriment to the rights of third parties.

IV. AGGRAVATING FACTORS

AFIANZA recalls that in the Agreement to initiate the sanctioning procedure, it is proposed to sanction it for:

- Violation of Article 5.1.f) GDPR with a fine of €100,000
- Violation of Article 32 GDPR with a fine of €60,000

And that both violations are aggravated by:

- Art. 83.2.b) GDPR intentionality or negligence in the violation. According to the AEPD, although intentionality is not observed, negligence is noted because “there was a storage of personal data on a removable device without being encrypted.”

At this point, AFIANZA reiterates what was stated in the section regarding the “Security Measures implemented,” understanding that pivoting the sanctioning argument on the lack of encryption of the stolen USB is not appropriate, because:

- it is not a mandatory security measure and
- none of the security measures implemented by AFIANZA have been taken into consideration.

Therefore, AFIANZA argues that the diligence in the care of the protection of personal data for which it is responsible cannot be questioned solely for not having encrypted a USB that has been stolen when there are and were many other security measures in place.

Furthermore, it continues to argue that, according to the provisions of Articles 1,104, 1,101, and 1,089

of the Civil Code, and the doctrine that interprets them, “negligence” is the omission of that diligence which the nature of the obligation requires and corresponds to the circumstances of the persons, the time, and the place. The legal reproach is the lack of a proper and adequate behavior of a moderately responsible person, in accordance with the circumstances of the specific case. There are also rulings that qualify negligence as “carelessness,” an action contrary to the objective duty of respect and care for the legal good protected by the norm, including here the “disregard” or “diminution” of the duties of vigilance or care.

It is important not to forget the circumstances in which the events occur, namely, that the loss of the USB occurs during a crime of theft with force against things, as provided in Article 237 of the Penal Code. If the crime had not occurred, no one would have been able to access the USB. We are not dealing with carelessness or negligence, since there were security measures (it is important to remember that the location of the USB support was inside a backpack, on a shelf in a private office, which is located at C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/44

in offices that can only be accessed after passing through two main doors at the entrance of the building, one more door to access AFIANZA, walking through a twenty-meter hallway, and finally opening and entering that office).

- Art. 83.2.c) GDPR any measures taken by the data controller or processor to mitigate the damages suffered by the data subjects.

AFIANZA states that, according to this Supervisory Authority, “there is no record that AFIANZA reacted as quickly as possible and took necessary measures to mitigate the effects and risks”; however, since the notification of the security breach, the AEPD has in its possession the complaint filed by AFIANZA when not even 24 hours had passed since the theft. The most effective way to mitigate the effects of a crime is to report it, and that is precisely what AFIANZA did. This is without detriment to the activation of the relevant security measures, the sending of communications to the community of property owners, as well as the notification to the AEPD itself.

In addition to the above, AFIANZA reminds that, on July 2, 2021, the Director of the AEPD requested the communication of the breach to the data subjects, a communication that AFIANZA carried out through the National Court and informed the AEPD on July 8, 2021. This matter has also not been valued by this Supervisory Authority.

AFIANZA reiterates that, more than a year later, there has been no damage or harm suffered by any data subject, making it entirely disproportionate to aggravate an infringement with this argument.

- Art. 83.2.g) GDPR the categories of personal data affected by the infringement.

AFIANZA points out that the AEPD establishes this aggravating factor by understanding that the USB contained data “related to infringements and criminal sanctions,” although, (...), it included the preliminary proceedings of the procedure, meaning that the information was related to the investigation process, with no criminal sanctions involved.

V. MITIGATING FACTORS

AFIANZA argues that, while the AEPD has decided to include the aggravating factors indicated in the previous point in both infringements, it has not taken into account any of the possible mitigating factors that could apply to the case:

- Art. 83.2.a) GDPR the nature, severity, and duration of the infringement. The alleged breach of confidentiality occurs in the context of a crime committed by a third party external to the organization, bypassing the established security measures. Furthermore, as has been repeatedly stated, there is no evidence that any third party has made use of the information contained in the USB, so the severity of the access from the perspective of data protection is nonexistent.

- Art. 83.2.c) GDPR any measures taken by the data controller or processor to mitigate the damages suffered by the data subjects and Art. 83.2.

C/ Jorge Juan, 6

www.aepd.es

f) GDPR, the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement. As indicated in the previous section, the AEPD has used this argument as an aggravating factor; however, both provisions should be taken into consideration given the proactive attitude that AFIANZA has demonstrated at all times, not only in collaboration with the AEPD (providing additional information, informing about communications to the affected parties...), but also with the affected parties.

- Art. 83.2.h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent. The AEPD would never have been aware of the fact had it not been for AFIANZA, in pursuit of fulfilling its proactive responsibility, directly communicating it. The time elapsed has shown that if AFIANZA had not reported it, the AEPD would never have been aware of the fact, as there has been no one whose freedoms or rights have been diminished by this incident.

- Art. 83.2.k) any other mitigating factor applicable to the circumstances of the case, applied by the AEPD in other proceedings, such as:

- The nonexistent extent of the damage. No individual has seen their rights and freedoms diminished.
- AFIANZA has taken measures to prevent similar incidents from occurring.
- AFIANZA has responded to the Agency's information request, which impacts cooperation with the supervisory authority in order to remedy the infringement and mitigate its possible adverse effects.
- There is no evidence that AFIANZA acted with intent or with a lack of diligence.
- AFIANZA is a small company.

VI. NON-EXISTENCE OF THE PRINCIPLE OF CULPABILITY

AFIANZA argues that the events that occurred would imply a result not pursued by it, as it was motivated by the commission of a criminal act by a third party completely unrelated to the data controller and its personnel, and it must be taken into account that, as the National Court points out, and to the extent that:

- (i) there is no voluntariness in the act,
- (ii) no particularly harmful result has occurred,
- (iii) there is no evidence of a lack of care in AFIANZA's actions in its activities and functions,

It would be contrary to the nature of the administrative sanctioning framework, subject to the principles of minimal intervention and proportionality, to impose a sanction regarding the event that occurred, which does not warrant sanctioning action as the element of culpability is not present.

AFIANZA indicates that the Judgment of the National Court of December 14, 2006, appeal no. 1363/2005, states in its Legal Foundations the following: "The resolution of this appeal begins by recalling, first of all, that culpability...

is an indispensable element for the sanction imposed on the claimant, as prescribed by Article 130.1 of Law 30/1992 of November 26, which establishes that only those responsible for acts constituting administrative infractions can be sanctioned, even in the case of mere non-compliance." Therefore, it argues that what was communicated by AFIANZA cannot be a reason to govern objective liability for establishing a sanction within the framework of administrative law. Indeed, in sanctioning matters, the principle of culpability applies (SsTC 15/1999, of July 4; 76/1990, of April 26; and 246/1991, of December 19), which means that some kind of intent or fault must be present. As stated in the Supreme Court ruling of January 23, 1998, "...there can be said to be a decisive line of jurisprudence that rejects objective liability in the sanctioning sphere of the Administration, requiring the concurrence of intent or fault, in line with the interpretation of STC 76/1990, of April 26, which indicates that the principle of culpability can be inferred from the principles of legality and prohibition of excess (Article

25 of the Constitution) or from the inherent requirements of the Rule of Law." This argument has already been put forward by the AEPD in similar proceedings, where the closure of the actions has been agreed upon (Procedure No.: PS/00112/2021), and it is that:

(i) The theft of the backpack does not correspond to a voluntary act of AFIANZA but rather to that of a third party unrelated to the entity.

(ii) No type of injury to the rights and freedoms of third parties has occurred. The extent of the damage is completely nonexistent.

(iii) The actions of AFIANZA at all times correspond to the due diligence required of a data controller.

For all these reasons, AFIANZA requests:

I. The closure of the sanctioning procedure of the AEPD insofar as there is no basis for sanctioning for alleged infringements of the GDPR that have not resulted in any detriment to the rights and freedoms of any third party. The extent of the damage is not measurable or quantifiable because it is nonexistent. As has been proven, neither the AEPD nor any other third party has the capacity to prove that, to date, there has been an "unauthorized access" or an "accidental disclosure" of the information contained in the USB, so the security breach for the legal effects indicated in the GDPR has not materialized. Likewise, the principle of culpability does not apply in any way, so any sanction would be contrary to the nature of the administrative sanctioning sphere, subject to the principles of minimal intervention and proportionality.

II. That the security measures implemented by AFIANZA and consistent with the current regulatory framework be accepted as true and applied.

III. That the activities carried out by AFIANZA throughout the proceedings and highlighted in the mitigating factors be valued.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/44

EIGHTH: On January 23, 2023, the instructing body of the sanctioning procedure made a proposal for resolution, in which it proposes that the Director of the AEPD sanction AFIANZA ASESORES, SL, with NIF B83117804:

- for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, with a fine of NINETY THOUSAND EUROS (90,000 euros)

- for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of FIFTY-FIVE THOUSAND EUROS (55,000 euros)

This proposal for resolution, which was notified to AFIANZA in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on January 26, 2023, as evidenced by the acknowledgment of receipt in the file.

In this proposal for resolution, in response to the allegations made by AFIANZA, the following response was given:

1. Security breach

The entity argues that it has not suffered a breach of confidentiality since it has not been proven that there was unauthorized access by a third party to the information contained in the stolen USB, as the only proven fact is the theft of such a device, but not access to its content.

In this regard, it should be noted that in the case at hand, there was the theft of an external storage device (USB) containing numerous pieces of personal information related to a criminal judicial investigation, and that it was neither encrypted nor had any other measures in place to prevent access to that information by unauthorized third parties in the event of loss or theft, which undoubtedly constitutes a violation of the confidentiality of the personal data contained, as it has been clearly compromised due to the lack of any protection for the device.

In this sense, the European Data Protection Committee (hereinafter, the Committee) makes it clear and without any doubt when, in Guidelines 01/2021 "on examples regarding personal data breaches.

Notification," adopted on December 14, 2021, it precisely states in its section 5.2, Case No. 11: Stolen material storing unencrypted personal data, that "This data breach refers to the confidentiality of the data stored on the stolen device" (point 94).

In this regard, the Committee is clear in indicating, subsequently, that the device containing the personal data was "vulnerable in this case because it had no password protection or encryption" (point 95)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/44

Furthermore, the Committee continues to assess that, due to these circumstances, notification to the Control Authority and notification to the interested parties is also necessary (point 98).

Therefore, asserting that although a device containing personal data stored on it was taken without any type of access protection, it does not constitute a breach of confidentiality because it cannot be demonstrated that anyone accessed it, would be equivalent to claiming that, in the event of a folder or book containing the same documentation in paper being stolen, it would not constitute a breach of confidentiality by arguing the impossibility of credibly proving that the person who took it or another third party did not open it. In both cases, what is relevant to understanding the breach of confidentiality is that the information is completely at the free disposal of unauthorized third parties.

Moreover, in the case of portable electronic storage devices, there exists the ability and possibility to protect them through technical security measures that make access to them by third parties impossible or considerably difficult. Therefore, in the present case, since none of these measures were established on the stolen USB, it constitutes a breach of confidentiality and, consequently, of Article 5.1 f) of the GDPR, which precisely requires that personal data be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality").

Thus, it cannot be argued in any way that the confidentiality of personal data remained intact, since, due to the lack of prior security measures, the personal data stored on that device is accessible.

The duty of confidentiality obliges not only the data controller but also anyone involved in any phase of the processing. This duty of secrecy means that the controller of the stored data cannot reveal or disclose its content, having the "duty to keep it." It is a fundamental requirement that precedes the very recognition of the fundamental right to informational self-determination referred to in the Constitutional Court Judgment 292/2000, of 30/11, and for the purposes now at hand, it entails that the processed data cannot be known by any person or entity outside the cases authorized by law, as this is precisely what secrecy consists of.

This duty of secrecy, of confidentiality, is essential in increasingly complex modern societies, where advances in technology place individuals in risk zones for the protection of fundamental rights, such as privacy or the right to data protection enshrined in Article 18.4 of the Spanish Constitution. Indeed, this provision contains a "guarantee institute for the rights of citizens that is, moreover, in itself a fundamental right or freedom, the right to freedom against potential assaults on the dignity and freedom of the person arising from the unlawful use of mechanized data processing" (Constitutional Court Judgment 292/2000, of 30/11). This fundamental right

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/44

The protection of personal data aims to guarantee individuals a degree of control over their personal data, its use, and destination, preventing situations that may infringe upon the dignity of the person, that is, the power to safeguard their private life from unwanted publicity.

In the case at hand, it has been established that AFIANZA has violated this duty of confidentiality

regarding the personal data contained in the USB related to a criminal case. This information cannot be provided to third parties, unless there is consent from the affected individuals or a legal provision that allows its communication, circumstances that do not apply in the present case. All of this constitutes a violation of Article 5.1.f) of the GDPR, as it has allowed, due to the absence of protective measures, third parties to access personal data of the affected clients.

2. Security Measures Implemented

AFIANZA claims that it has implemented all necessary technical and organizational measures to ensure an adequate level of security relative to the risk involved in processing personal data, referring in its written submissions to a list of these measures and asserting that it complies with the requirements of Article 32 of the GDPR, as well as with each and every principle related to processing, especially the principle of confidentiality, noting that security is not infallible and that it cannot be held responsible for being a victim of a criminal act or for the breach of security measures by a third party. In this regard, it also indicates that the aforementioned provision does not regulate a list of applicable security measures, therefore AFIANZA understands that it is not appropriate to base the sanctioning procedure on the lack of encryption of the stolen USB, as it is not a mandatory measure under Article 32 of the GDPR and, moreover, it considers that none of the security measures implemented by AFIANZA and previously communicated have been taken into account.

In response, it should be noted that, from the events that occurred, the opposite is deduced. Thus, in the case at hand, access was gained by an unauthorized person to the entity's premises without the implemented security measures functioning or being observed, and the theft of an unencrypted USB device (or without any other protective measure) occurred, containing numerous personal data related to a criminal judicial investigation procedure.

Regarding the assertion that it had all the appropriate security measures and that these have not been taken into account by this Agency, it is stated that, as already indicated in the Initiation Agreement of the present sanctioning procedure, the security measures that AFIANZA claims to have implemented were not being complied with at the time of the events.

Thus, from the analysis of the documentation provided by AFIANZA in response to the information request regarding the causes that made the breach possible, and the security measures in place before the breach as stated by AFIANZA at that time, the following results:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
13/44
(...)

However, in the case at hand, the device was not encrypted nor did it have any other information protection measures in place.

Therefore, it can be deduced that there was a lack of due diligence both in complying with the established security measures and in supervising or verifying their observance and/or suitability. In this regard, it is noted that Article 32 of the GDPR is infringed both if the controller does not adopt appropriate technical and organizational measures to ensure the security of personal data, and if, once established, these measures are not observed. It is precisely this lack of observance that constitutes the infringement indicated in Article 73 of the LOPDGDD, as it states that, according to what is established in Article 83.4 of Regulation (EU) 2016/679, serious infringements that involve a substantial breach of the articles mentioned therein are subject to a two-year limitation period, particularly including the following:

g) The breach, as a consequence of the lack of due diligence regarding the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.” (...)

Finally, regarding the fact that Article 32 does not regulate a list of specific security measures, and that encryption is not a mandatory security measure, it should be noted that this provision establishes, in its paragraph 1, the obligation for controllers and processors to apply appropriate technical and

organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons.

Furthermore, paragraph 3 of the same provision states that, when assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the data processing, particularly as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

Therefore, Article 32 does not indeed establish specific and static security measures; rather, it is up to the controller to determine the necessary security measures to ensure the confidentiality, integrity, and availability of personal data. Consequently, the same data processing may involve different security measures depending on the specific circumstances in which that data processing takes place.

Additionally, Recital 83 of the GDPR states: In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/44

of the technique and the cost of its application concerning the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may particularly cause physical, material, or immaterial harm.

In short, the first step in determining the security measures that must be applied to the specific processing will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating the risks associated with data processing.

The principle of data security requires the application of appropriate technical or organizational measures in the processing of personal data to protect such data against unauthorized or unlawful access, use, modification, dissemination, loss, destruction, or accidental damage. In this sense, security measures are key to ensuring the fundamental right to data protection. The existence of the fundamental right to data protection is not possible if the confidentiality, integrity, and availability of such data cannot be guaranteed.

And it is emphasized, in accordance with Article 32.1 of the GDPR, that the technical and organizational measures to be applied to ensure an adequate level of security relative to the risk must take into account the state of the technique, the costs of application, the nature, scope, context, and purposes of the processing, as well as the variable likelihood and severity of risks to the rights and freedoms of natural persons.

Therefore, based on the activity it engages in and the personal data it processes, AFIANZA is obliged to conduct a risk analysis and implement appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its activity for the rights and freedoms of individuals, taking into special account that its activity involves processing personal data related to criminal convictions and offenses.

When referring to data related to "criminal convictions and offenses," it pertains to a category that includes personal data processed for the purposes of preventing, detecting, investigating, and prosecuting criminal offenses and enforcing criminal sanctions.

The processing of this category of personal data poses a high risk to the rights and freedoms of the individuals to whom it pertains, a risk whose assessment and analysis by the data controller is required

by the GDPR in several of its provisions and recitals, in addition to Article 32, and which will entail the adoption of appropriate security measures.

Additionally, the risk posed by storing such data on external and portable devices (specific context of the processing) must be evaluated, including, clearly, the risk of loss or theft (high probability risk) and adopt appropriate security measures, in accordance with the state of the technique and the costs of application. In relation to this last point, the state of the technique allows for easy and...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/44

It is somewhat inexpensive to implement a protective security measure in the case of storing personal data on external and portable USB-type devices: their encryption or any other technical protection measure against access by unauthorized third parties (data encryption, password for access, etc.). It is a basic, accessible, and easily implementable measure, in accordance, as mentioned, with the current state of the art.

In this case, as previously noted, AFIANZA suffered the theft of a USB device on which personal data had been stored without any type of protection (...).

Therefore, what is being reproached is the storage of this category of personal data on a completely unprotected USB, that is, on an external device without any type of technical security measure, without any type of protection to prevent access by unauthorized third parties, which clearly constitutes a breach of Article 32 of the GDPR.

3. Notification period for the security breach

In this section, AFIANZA makes several statements.

Thus, it argues that the period established in Article 33 of the GDPR is not a mandatory period.

In response, it should be noted that the notification period to this Agency in the event of a personal data security breach is a mandatory period: without undue delay and, if possible, no later than 72 hours after becoming aware of it. Therefore, this is the maximum period allowed for making the notification. Likewise, and in line with it being a mandatory period, Article 74 m) of the LOPDGDD classifies as a minor infringement the incomplete, late, or defective notification to the data protection authority of information related to a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679.

Furthermore, AFIANZA indicates that as soon as it assessed the potential damage or risk of the breach, it notified the Agency and that, since there was no publication or any other misuse of the information contained in the USB, the security breach has not materialized.

In this regard, it is noted that the fact that no damage or publication of the data has been recorded does not mean that the breach has not materialized, as it occurs from the very moment the security incident that caused a breach of the confidentiality of the data takes place.

Finally, AFIANZA states that any data controller could have chosen never to report the criminal act to the AEPD and that, by doing so, it demonstrated a proactive attitude.

In response, it is reminded that the notification of security breaches to the supervisory authorities and communications to the affected parties, when applicable, are required.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/44

The assumptions established by Articles 33 and 34 of the GDPR are not an option but an obligation imposed by legal imperative, in this case, by a directly applicable European regulation, and failing to comply constitutes a violation of the same, classified as an infringement in Article 83.4.

4. Aggravating Factors

AFIANZA clearly disagrees with the aggravating circumstances taken into account when determining

the calculation of the sanction. Thus:

- Art. 83.2(b) GDPR. Intentionality or negligence in the infringement

AFIANZA states that it is not appropriate to observe the existence of negligence regarding the storage of personal data on a removable device without encryption, as it believes that it is again inappropriate to pivot the sanctioning argument on the lack of encryption of the stolen USB and that the other measures have not been considered.

In this regard, it is appropriate to refer to the arguments made in the previous section (section 2) of this Legal Basis, regarding the lack of observance or compliance with the organizational and technical security measures that AFIANZA claims to have implemented (which allowed an unauthorized person to access without difficulty, without forcing anything, the premises of AFIANZA and steal the USB), as well as the failure to adopt a basic security measure such as storing personal data related to a criminal judicial procedure on a completely unprotected removable device, despite the risk of theft or loss that this entails.

All of this demonstrates a clear lack of diligence on the part of AFIANZA in verifying and monitoring the observance and compliance with the implemented security measures and/or their continuous effectiveness and suitability, as indicated in the Initiation Agreement and reproduced in this resolution proposal at the time of motivating the circumstances to be considered in the grading of the sanctions (Legal Bases VI and IX), to which we refer in order to avoid repetitions.

- Art. 83.2(c) GDPR. Any measures taken by the controller or processor to mitigate the damages suffered by the data subjects.

AFIANZA argues that it does not agree that it has been considered an aggravating circumstance that it "did not react as quickly as possible and did not take the necessary measures to mitigate the effects and risks on the rights and freedoms of the affected individuals, including notifying this Agency and communicating the incident to the affected parties without undue delay."

In this regard, it should be noted that notifying the supervisory authorities and communicating the security breach to the affected parties are obligations imposed on the data controller by the GDPR (Articles 33 and 34 respectively), that is, their observance is mandated by legal imperative, so their compliance or...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/44

non-compliance, in accordance with the requirements set forth in such provisions, may imply violations thereof.

The circumstance to be taken into account contained in Article 83.2 c), therefore, must refer to other types of measures that the data controller or processor may adopt in order to reduce, as much as possible, the impact of a violation or breach of security.

For the reasons stated, it is not appropriate, in this case, to consider the aggravating factor indicated in the Initiation Agreement, and consequently, it is appropriate to reduce the amount of the sanctions for both violations.

- Art. 83.2 g) GDPR. The categories of personal data affected.

AFIANZA states in this regard that the data contained in the USB was information related to the criminal investigation process, and therefore there were no data related to criminal sanctions.

In this regard, it is noted that when referring to data related to "convictions and criminal offenses," it is referring to a category that includes personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and enforcement of criminal sanctions. This category includes the information stored in the stolen USB, as it contained personal data (...).

5. Mitigating Factors

AFIANZA argues that when assessing the amount of the violation, the mitigating circumstances it points out should be taken into account. However, in response to this, the following is noted:

- Regarding the consideration of Article 83.2.a) GDPR (nature, severity, and duration of the violation) as a mitigating factor, in the sense that, since it cannot be proven that a third party accessed the USB,

the severity of the access from the perspective of data protection is non-existent, it is noted that such an interpretation should not be accepted. Thus, on the one hand, it has already been stated in section 1 of this Legal Basis that the theft of an external device without any type of protective measure against access and containing personal data already constitutes a violation of the confidentiality of the same, which constitutes a breach of Article 5.1 f) of the GDPR, classified as a very serious infringement in Article 83.5 of the aforementioned Regulation.

- Regarding whether the circumstances set forth in Articles 83.2 c) GDPR (any measures taken by the data controller or processor to mitigate the damages suffered by the affected parties) and 83.2 f) (degree of cooperation with the supervisory authority in order to remedy the violation and mitigate the possible adverse effects of the violation) should be considered as mitigating factors, AFIANZA understands that it acted at all times with a proactive and collaborative attitude with this Agency by notifying it of the security breach and by addressing the notification requirement to the affected parties and informing it of this, it should be clarified that all of this does not reflect a proactive and collaborative attitude, but rather are...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/44

legal requirements that AFIANZA is obliged to comply with as the data controller, under penalty of incurring violations of the GDPR.

Therefore, the degree of cooperation with the Agency cannot be considered a mitigating factor since the orders and requests issued by it are mandatory. The consideration of cooperation with the Agency as a mitigating factor, as the entity intends, is not linked to any of the cases in which there may be collaboration or cooperation or request due to a legal mandate, when the actions are due and required by law, as in the case at hand.

6. Non-concurrence of the principle of culpability

AFIANZA argues that the events that occurred represent an outcome not pursued by AFIANZA, as they were produced through the commission of a criminal act by a third party completely unrelated to the data controller and its personnel, as well as that there was involuntariness in the act, no particularly harmful outcome occurred, and there is no evidence of a lack of care in AFIANZA's actions, so the element of culpability necessary to impose a sanction does not concur.

In response, as has been stated in previous sections of this legal basis, AFIANZA is not sanctioned for having suffered a criminal act (the theft of the device), but for the lack of adequate measures both to safeguard the confidentiality of the personal data it handles (storage of personal data related to infractions and criminal sanctions on an external device without any protective measures against access by unauthorized third parties) and for the non-observance or non-compliance with the security measures that were in place (physical and logical controls in its premises).

All of this demonstrates a lack of due diligence in the measures that AFIANZA, as the data controller, is obliged to effectively adopt and verify that they are observed and that they are effective and adequate, among which, above all, are those aimed at preventing unauthorized access by third parties to the personal data for which it is responsible.

The principle of culpability is required in the sanctioning procedure, but the principle of fault does not imply that only intentional actions can be sanctioned. The Supreme Court (STS April 16, 1991, and STS April 22, 1991) considers that from the culpability element it follows “that the action or omission, qualified as an administratively sanctionable infringement, must, in any case, be attributable to its author, whether by intent or negligence, imprudence, or inexcusable ignorance.” The same Court reasons that “it is not enough...for exculpation against a typically unlawful behavior to invoke the absence of fault” but it is necessary “that the diligence required by the one alleging its non-existence has been employed.” (STS January 23, 1998).

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or non-compliance is sufficient.”

the duties that the Law imposes on the persons responsible for files or the processing of data to exercise utmost diligence..." (SAN June 29, 2001).

For all the above reasons, it is appropriate to dismiss the allegations made.

NINTH: On February 9, 2023, a letter from AFIANZA was received by this Agency, in due time and form, in which it presents allegations to the proposed resolution, stating, in summary, that:

I. SECURITY BREACH AND IMPLEMENTED SECURITY MEASURES

The AEPD refers in its Proposal for Resolution that the European Data Protection Committee (hereinafter, Committee), in its Guidelines 01/2021, indicates that:

- (i) This data security breach affects the confidentiality of the data stored on the stolen device (point 94).
- (ii) The personal data was vulnerable in this case because it lacked protection through a password or encryption (point 95).
- (iii) Due to these circumstances, notification to the AC is necessary, and therefore notification to the affected parties is also necessary (point 98).

It is essential to consider that these arguments put forth by the AEPD point to a specific example raised in those Guidelines of the Committee and do not correspond to the reality of the event that occurred and was communicated by AFIANZA, so using the same as support for the legal argumentation of this Control Authority implies absolute defenselessness on the part of AFIANZA, which, using this same criterion, could argue that in the Guidelines on the notification of personal data security breaches according to Regulation 2016/679 of the Article 29 Working Group (Guidelines on which Guidelines 01/2021 are based), it is indicated as an example that i. A data controller who kept a backup copy of a file of encrypted personal data on a USB stick. The stick disappears during a theft, should not notify either the Control Authority or the affected parties. Certainly, as has been reported from the beginning, the USB was not encrypted, but there were other security measures in place at AFIANZA aimed at making access to the information impossible or considerably difficult.

Similarly, in the stolen backpack, there was also an iPad, the conditions of which fit within 5.1 CASE NO. 10: stolen material that stores encrypted personal data from Guidelines 01/2021, and in which, as concluded therein:

- (i) In this specific case, the data controller adopted appropriate measures to prevent and mitigate the effects of a possible data security breach through the encryption of devices, the introduction of adequate password protection, and the protection of the data stored on the tablets (point 88).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/44

- (ii) The data security breach described above would have affected the confidentiality, availability, and integrity of the data in question; however, due to the appropriate procedures of the data controller before and after the data security breach, none of these aspects were affected (point 89).

In this context, the punitive and accusatory attitude of the AEPD regarding the USB is striking, while, concerning the iPad, the security measures implemented are neither acknowledged, valued, nor taken into consideration.

The AEPD in its Proposal for Resolution states that "what is relevant to understand the breach of confidentiality is that the information is completely at the free disposal of unauthorized third parties." To assert this is to assume that AFIANZA has not complied with any of the obligations inherent to its role as the data controller and that it has not only failed to establish security measures but also "facilitates" third-party access to the information for which it is responsible.

Referring to Guidelines 01/2021, this Supervisory Authority must be aware that, in them, in addition to multiple practical examples of specific situations regarding what constitutes a security breach or not, there is a list of measures that is neither exclusive nor exhaustive, regarding what organizational and technical measures are recommended to prevent or mitigate the impact of loss or theft of devices, including:

- Use an access code or password on all devices.

- Use multi-factor authentication.
- Activate the functionalities of mobile devices that allow revoking access permissions in case of loss or misplacement.
- If the workstation is connected to the corporate LAN, make an automatic backup of the work folders whenever it is unavoidable that personal data is stored there.
- Use a secure VPN (for example, one that requires an independent second-factor authentication key for establishing a secure connection) to connect mobile devices to back-end servers.

Each and every one of these measures was implemented at AFIANZA as of June 17, 2021; evidence of this can be found in how the remote deactivation and subsequent revocation of access to the iPad, which was also in the backpack, were carried out.

In addition to the above, the Guidelines also include as recommended security measures: providing physical locks to employees so that they can physically protect the mobile devices they use while they remain unattended and installing physical access controls, measures that, as has been argued and proven throughout this procedure, were also implemented at AFIANZA.

In any case, these Guidelines are about the notification of security breaches, which implies that they are mere tools to determine whether we are or not...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/44

not before a security breach, and in the event that one has occurred, how to act regarding its communication. In no case does the duty to notify a security incident adhere to a breach or lack of security measures, nor to a breach of the principle of confidentiality, and much less to an automatic imposition of sanctions.

II. INFRINGEMENT OF ARTICLE 32 OF THE GDPR

This Supervisory Authority understands that AFIANZA has clearly violated Article 32 of the GDPR by storing personal data on an entirely unprotected USB, that is, on an external device without any type of technical security measure, without any protection to prevent access by unauthorized third parties.

The first step to determine the security measures that must be applied to the specific processing will be the risk assessment; once this is carried out, it will be necessary to determine the security measures aimed at reducing or eliminating risks for the processing of data.

In this regard, AFIANZA, prior to the commission of the theft, and in compliance with the principle of proactive responsibility, had conducted its risk analysis and defined its security measures, both technical and organizational measures, measures that go beyond mere encryption which, we reiterate, was implemented in other tools of AFIANZA (such as in the iPad itself). To assert that "there were no security or protection measures" is to deny the proven facts and act punitively.

AFIANZA acknowledges that, at the exact moment of the theft, a series of circumstances occurred that led to the non-applicability of some of the security measures implemented and already discussed, but this is very different from asserting that none existed. The clear evidence is the comparison between the treatment given to the iPad and the USB.

To seek to impose a fine of €55,000 is absolutely disproportionate, not only due to the lack of valuation by the AEPD of AFIANZA's control measures, or the negligible impact that the event has had, but also due to the very comparison with the sanctioning resolutions that this Supervisory Authority has been imposing on other entities for the commission of the same infringement. Indeed, after analyzing the total of 61 Resolutions available through the AEPD's website related to the infringement of Article 32 of the GDPR in sanctioning procedures, it is evident that, in relation to the private sector:

(I)

In cases where a security incident has occurred, in which Article 32 of the GDPR has been violated, resulting from the abandonment of documents that, in some cases, even contain sensitive personal data, allowing access to them by third parties with a breach of the established measures, the sanction imposed by the AEPD has been €3,000.

In these cases, although there is no evidence of access to the information by third parties, the attitude

of the responsible party...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/44

treatment is active in the sense of leaving the documentation (including medical documentation) freely accessible to third parties.

(II) There are many other cases in which, according to the AEPD, there are clear indications that the sanctioned party has violated Article 32 of the GDPR, as a security incident occurred in their system allowing access to personal data of a third party, permitting access to information that contained third-party data, in breach of the established measures. These sanctions range from a Warning to €5,000 for small businesses, while for large companies, the sanctions range between €30,000 and €60,000:

At this point, AFIANZA questions why, if in this case, the AEPD maintains that there has been a violation of Article 32 of the GDPR, the proposed sanction against AFIANZA is similar to that imposed on large companies such as XFERA MÓVILES, S.A or VODAFONE ONO, S.A.U, even though in this case, and unlike these:

(i) there is no evidence that any third party has actually accessed the information contained in that USB;

(ii) the AEPD became aware of the matter through AFIANZA, not from third parties who may have seen their rights violated as happens in the vast majority of the analyzed cases collected here; and

(iii) 20 months after the theft, the interests and freedoms of none of the affected parties have been compromised, with no complaints or claims filed with any competent entity or institution for these purposes.

(III) In addition to the above cases, a comparison is presented between two very similar events in terms of fact and data type, but absolutely different regarding the sanction, the application of mitigating factors, the number of affected parties, and, in general, the assessment by the AEPD:

AFIANZA again questions why (i) if the volume of affected data in the case of CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA is 100 times greater than that of the data affected in the case of AFIANZA;

(ii) if the type of data in the case of CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA affects many more special categories of data (union membership data; health data, complete judgments; notification of embargo; pension plan data, etc.) than in the case of AFIANZA; and (iii) if there has been a complaint from affected parties before this Control Authority in the case of CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA, which has not occurred in the case of AFIANZA,

(i) Why in the case of CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA are mitigating factors taken into account and not in the case of AFIANZA?

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/44

(ii) Why is AFIANZA penalized for the violation of Article 32 and, additionally, for that of Article 5.1.f) of the GDPR, while CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA is not?

(iii) Why is the proposed sanction against AFIANZA, in relation only to Article 32 of the GDPR, practically identical, and in relation to the total proposed, almost three times more than that finally imposed on CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA?

Through this comparative exercise, the absolutely disproportionate nature of the sanction proposed by the AEPD against AFIANZA has been demonstrated, as in similar situations the AEPD even imposes a warning when it considers that the administrative fine that could be imposed would constitute a

“disproportionate burden.”

Furthermore, the AEPD tends to value in its resolutions that no previous infringement in data protection has been committed, a fact that also leads to a result without a fine, a matter that has not been taken into consideration with AFIANZA.

III. VIOLATION OF ARTICLE 5.1.F) OF THE GDPR

Article 5.1.f) of the GDPR states that personal data shall be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures.

This principle of “security” imposed by the GDPR on those who process data necessitates conducting a risk analysis aimed at determining the necessary technical and organizational measures to ensure the integrity, availability, and confidentiality of personal data. Measures that are both technical and organizational, which, as has been stated, existed at AFIANZA. A different matter is that on a specific day at a specific time and due to specific circumstances, there was a failure in the applicability of some of the implemented security measures already discussed, but this is very different from stating that none existed, as well as being very different from assuming that the principle of confidentiality has been violated.

In the previously mentioned case of CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA, this Control Authority does not even assess the possible violation of this article.

All the facts evaluated here occur as a result of a criminal activity, presumably organized and planned. We are not facing a failure to comply with measures by AFIANZA, and the judgments of the National Court (hereinafter, SAN) (Contentious-Administrative Chamber, hereinafter, SCA) of February 25, 2010 [JUR 2010/82723] and November 10, 2017 [JUR 2018/3170] indicate that (...). Thus, the fact that a third party has overcome these measures

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/44

does not imply, per se, a breach of the obligation or, as the case may be, the principle of integrity and confidentiality. The data controller is subject to an obligation of means, not an obligation of result in the sense of understanding that every incident is a breach of the duty to "ensure a level of security appropriate to the risk" (Article 32 of the GDPR).

This argument seems to align with the resolutions that the AEPD has imposed on those who have infringed Article 5.1.f) of the GDPR, and it follows that from a superficial analysis, it can be inferred that the AEPD has been imposing the infringement of Article 5.1.f) in those cases where there has indeed been unauthorized access to information by third parties, that is, those cases where it is proven that third parties have accessed information to which they were not entitled, an element that does not occur in the case we are discussing here.

Nevertheless, AFIANZA reiterates compliance with the principle of confidentiality and requests this Supervisory Authority to differentiate between failures in the applicability of security measures at the time of the theft, and the breach of the principle of confidentiality. Both infringements do not necessarily have to go hand in hand, and this has been stated on numerous occasions by the AEPD; it is necessary to review its resolutions. Moreover, in very similar cases (CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA and AFIANZA), the outcomes proposed by the AEPD are completely different.

IV. AGGRAVATING FACTORS

The proposed Resolution of the AEPD, despite having reconsidered the application of the aggravating factor contemplated by Article 83.2.c), maintains the following aggravating circumstances:

- Art. 83.2 b) GDPR: Intentionality or negligence in the infringement.

In the present case, there is an evident lack of "culpability" on the part of AFIANZA, an essential requirement for determining the application of the aggravating factor set forth in Article 83.2.b).

Culpability requires the assessment of intent (ruled out at all times), recklessness, or negligence, with

the latter two concepts being used interchangeably by the AEPD.

The AEPD perceives negligent conduct in the two violations attributed to AFIANZA concerning Articles 5.1.f) and 32 GDPR. However, AFIANZA is unaware of the reasons and arguments corresponding to each of the alleged infringements.

The Resolution of the AEPD has not specified which actions or omissions of AFIANZA should be attributed to any of the aggravating circumstances; it has simply limited itself to judging both violations jointly, without breaking down or developing the reasons why negligence is perceived regarding the breach of the principle of confidentiality (Article 5.1.f) GDPR), nor regarding the adoption of appropriate security measures (Article 32 GDPR).

Given the circumstances of this case, negligent conduct cannot be appreciated. As previously stated in earlier submissions, negligence implies a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/44

omission of that diligence which the nature of the obligation requires and corresponds to the circumstances of the persons, the time, and the place, in accordance with Articles 1,104, 1,101, and 1,089 of the Civil Code.

In the present case, AFIANZA has not engaged in any active behavior that has violated the principle of confidentiality or breached the appropriate security measures, such as the publication of personal data on a website or sending an email to multiple recipients without using the BCC function (as occurs in the cases outlined in Annex I).

At no time did AFIANZA carry out acts that jeopardized the security and confidentiality of the data, that is, it did not make decisions knowingly aware that they could lead to harmful consequences. On the contrary, AFIANZA has demonstrated proactive responsibility, having established both physical barriers related to the building's infrastructure and security personnel, as well as technical measures with the encryption of most devices; however, AFIANZA acknowledges and has reported from the very beginning that some of these security measures were not applied at the exact time and date of the theft, which is different from assuming that they did not exist or had never been applied before.

In this regard, the Guidelines on the application and establishment of administrative limits for the purposes of the GDPR issued by the European Data Protection Board make the following observations regarding the aforementioned aggravating factor. The Board states that, in accordance with the GDPR, "the routines and documentation of processing activities are based on risk." Furthermore, "companies must be responsible for adopting structures and resources appropriate to the nature and complexity of their business."

At this point, it is necessary to reiterate the low probability of a backpack theft occurring in facilities where there are hundreds of higher-value devices, all protected by encryption systems. The risk of a crime of this magnitude being committed under the given circumstances in this specific case seems practically unimaginable.

- Art. 83.2.g) GDPR the categories of personal data affected by the infringement.

Regarding this aggravating factor, AFIANZA feels the need to state that data related to infringements and criminal convictions (the criminal investigation) had already been made publicly available prior to the day of the theft. (...)

That is to say, even though the data contained in the USB that was inside the stolen backpack relates to infringements and criminal convictions, the vast majority of what was included there had already been published in newspapers, radio, and TV. The risk of any new information being leaked or becoming known is nonexistent.

This criterion is supported by the Judgment of the Court of Justice of the European Union of November 24, 2011 (joined cases C-468/10 and C469/10), which indicates, in its Recitals 44 and 45, that when data appears in sources accessible to the public, the data controller and, where applicable, the third party or parties to whom it is disclosed...

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/44

they communicate the data do not access data relating to the private life of the data subject, given that the information is already publicly known. Consequently, there is a lesser impact on the rights of the data subject, which must be appreciated at its true value in the balancing with the legitimate interest pursued by the data controller or by the third party or parties to whom the data is communicated. The same can be said in the case of data that has been manifestly made public by the data subject (Article 9.2.e) GDPR), which also applies in the present case as many of those investigated have appeared in the media making statements about the case.

V. MITIGATING FACTORS

Despite the facts presented and the evident cooperative and favorable attitude of AFIANZA, the Resolution of the AEPD rejects the consideration of the following mitigating circumstances, which in our view should be valued:

- Art. 83.2.a) GDPR the nature, gravity, and duration of the infringement. It is appropriate to emphasize that, two years after the security breach, no revelation of any of the data contained in the stolen Pendrive has been confirmed. Furthermore, none of the nearly one hundred affected individuals have filed any complaints in this regard. While it is true that the USB with a considerable volume of data was stolen, the impact has been practically nonexistent. No consequences have been generated for the affected individuals, who have also not expressed their discomfort or disapproval.
- Art. 83.2.c) GDPR any measures taken by the data controller or processor to mitigate the damages suffered by the data subjects. From the moment AFIANZA became aware of the theft of the backpack, it acted promptly and effectively. First, by completely blocking the content of the iPad, a measure that has significantly reduced access to certain information. Subsequently, AFIANZA identified the personal data involved, the affected individuals, and contacted them to inform them of what had happened. Additionally, security and prevention protocols regarding the privacy and confidentiality of the information collected by the firm were implemented, as well as access to its facilities; training and awareness measures. None of these measures have been considered by the AEPD, unlike what happened in the case of CORPORACION DE RADIO Y TELEVISION ESPAÑOLA SA, previously mentioned.
- Art. 83.2.f) GDPR, the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement. Closely linked to what has been recently stated, it is pertinent to reiterate the collaborative attitude of AFIANZA. The AEPD states in the Resolution that the act of cooperating and providing the required information is a legal obligation and, consequently, should not be rewarded. Indeed, AFIANZA has complied in a timely manner with all obligations and requests from the AEPD since the moment it notified the security breach. From this perspective, we do not understand what the degree of cooperation should be in order for it to be...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/44

considered as a mitigating factor, especially when there are cases in which the entity being claimed against has not fulfilled the imposed obligations and the consequent aggravating factor has not been implemented.

- Art. 83.2.h) the manner in which the supervisory authority became aware of the infringement, particularly whether the responsible party or the data processor notified the infringement and, if so, to what extent.

AFIANZA indicates that it was the one who informed the AEPD of the security breach, a clear indication of the proactive responsibility and diligent action of the entity being claimed against. Although there was some delay in the notification period, it has been sufficiently evidenced during the present procedure (the passage of the weekend, gathering of information and affected individuals,

limitation of damage, etc.).

In this regard, it understands that the notification of the breach by AFIANZA demonstrates proactivity. That is to say, the loss or theft of a USB (a small-sized device) can easily go unnoticed and may not have been detected. However, AFIANZA has demonstrated that it has control over the company's devices in such a way that, at the very least, its loss or theft is detected, allowing measures to be adopted from early stages. It is not merely about having complied by notifying the breach to the AEPD, but rather that it was able to immediately detect that among the stolen goods, there was a USB containing personal data. This in itself denotes due diligence in the face of a personal data security breach.

Furthermore, given the negligible impact and the absence of claims from the affected individuals, if AFIANZA had not notified it, the AEPD would never have been aware of the fact.

- Art. 83.2.k) any other mitigating factor applicable to the circumstances of the case, applied by the AEPD in other procedures, such as:

- ☐ The nonexistent scope of the damage. No individual has seen their rights and freedoms diminished.
- ☐ AFIANZA has taken measures to prevent similar incidents from occurring in the future, and to date, they have proven to be effective.
- ☐ AFIANZA has responded to all requests from the AEPD, which reflects cooperation with the supervisory authority in order to remedy the infringement and mitigate its possible adverse effects.
- ☐ There is no evidence that AFIANZA acted maliciously or with a lack of diligence.
- ☐ AFIANZA is a small company.
- ☐ AFIANZA has not committed any previous infringement regarding data protection.
- ☐ AFIANZA was a victim of a premeditated theft, taking advantage of a spontaneously vulnerable situation of the security measures. This implies that, in addition to having suffered the intrinsic consequences as a victim of a crime, it has been judged for the same.

VI. NON-APPLICATION OF THE PRINCIPLE OF CULPABILITY

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/44

Regarding the principle of culpability, AFIANZA argues, as it did in its allegations to the initiation agreement of the sanctioning procedure, that it has not acted culpably, and therefore, no sanction should be imposed.

Article 28.1 of Law 40/2015, of October 1, regulates the principle of culpability, indicating that only individuals and legal entities, as well as, when a law recognizes their capacity to act, affected groups, unions, and entities without legal personality and independent or autonomous estates, that are responsible for the same due to intent or negligence, may be sanctioned for acts constituting administrative infractions.

Following the interpretation made by the Supreme Court, mere invocation of the absence of fault will not suffice for exculpation; it will be necessary to demonstrate that the diligence required by the party claiming its non-existence has been exercised (among others, the Supreme Court ruling of January 23, 1998 [RJ 1998\601]). Furthermore, the National Court has understood, in cases similar to the present one, where a third party has accessed data of the interested parties held by a data controller through criminal activities, that attributing such acts to the data controller could lead to a violation of the principle of culpability. By way of example, the SAN (Contentious-Administrative Chamber, Section 1) ruling of February 25, 2010 [JUR 2010/82723]. "Thus, even though Article 9 of the LOPD establishes an obligation of result, consisting of adopting the necessary measures to prevent data from being lost, misplaced, or ending up in the hands of third parties, such obligation is not absolute and cannot encompass a case like the one analyzed. In the case at hand, the result is a consequence of an intrusion activity, not protected by legal order and thus illegal, (...). And such acts cannot be attributed to the appellant entity, as doing so would violate the principle of culpability."

In no case can the theft of the backpack imply that AFIANZA has acted culpably. Consequently, it has acted with the due diligence that is required, and in accordance with the provisions of sanctioning law,

no sanction should be imposed.

On the other hand, it should be noted that the SAN -Contentious-Administrative Chamber 392/2015, of November 17, in its Legal Foundation Third, incorporates the doctrine of the Constitutional Court regarding the application of the principles of criminal law to administrative sanctioning law, in the following terms: "The Constitutional Court has repeatedly declared that the principles of criminal law, among which is the principle of culpability, are applicable, with certain nuances, to administrative sanctioning law, as both are manifestations of the punitive order of the State (STC 18/1987, 150/1991), and that objective or faultless liability cannot exist in the administrative sanctioning sphere, whereby the possibility of imposing sanctions based solely on the result is excluded, without demonstrating a minimum level of culpability even in the case of mere negligence (SSTC 76/1990 and 164/2005). The principle of culpability, guaranteed by Article 25 of the Constitution, limits the exercise of the State's "ius puniendi" and requires, as stated by the Constitutional Court in ruling 129/2003, of June 20, that the imposition of the sanction be based on the requirement of the subjective element of fault, to guarantee the principle of...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/44

responsibility and the right to a sanctioning procedure with all guarantees (STS of March 1, 2012, Rec 1298/2009).

In the case at hand, it is evident that there is no unlawfulness or culpability in the conduct of AFIANZA. Unlike the cases presented in sections II and III of this submission, AFIANZA does not engage in any actions aimed at failing to fulfill its obligations as the data controller; AFIANZA does not provide/send/communicate personal data of affected individuals to unauthorized third parties; AFIANZA does not violate the principle of confidentiality; AFIANZA does not engage in culpable conduct. AFIANZA has always complied with all obligations inherent to the data protection regulations concerning personal data, as demonstrated by the submission of documentation, the report, the communication of the breach, and other communications with the AEPD, which show that its conduct has always been in accordance with the diligence required of it. Furthermore, it has been evidenced that the necessary precautions have been adopted to prevent the non-consensual processing of data, and all affected individuals have been informed of the incident, although we reiterate that, 20 months later, this has had no or negligible impact on the affected individuals.

Nevertheless, in this case, the events that occurred would imply a result not pursued by AFIANZA, as it was motivated by the commission of a criminal act by a third party completely unrelated to the data controller and its personnel. Therefore, the necessary elements determined by the National Court to assume that AFIANZA's conduct has indeed been culpable are not present, namely:

- (i) there is no voluntariness in the act,
- (ii) no particularly harmful result has occurred,
- (iii) there is no evidence of a lack of care in AFIANZA's actions in its activities and functions.

This argument has already been put forward by the AEPD in similar proceedings, where the closure of the proceedings has been agreed (Procedure No.: PS/00112/2021), and it is as follows:

- (i) The theft of the backpack does not correspond to a voluntary act of AFIANZA but rather that of a third party unrelated to the entity.
- (ii) No type of injury to the rights and freedoms of third parties has occurred. The extent of the damage is completely nonexistent.
- (iii) AFIANZA's actions at all times correspond to the due diligence required of a data controller.

For all these reasons, AFIANZA requests:

I. The closure of the sanctioning procedure of the AEPD against AFIANZA to the extent that there is no basis for a sanction for alleged violations of the GDPR that have not resulted in any detriment to the rights and freedoms of any third party. The extent of the damage is not measurable or quantifiable because it is nonexistent. Likewise, the principle of culpability does not apply in any way, so any sanction would be contrary to the nature of the administrative sanctioning framework, which is subject

to the principles of minimal intervention and proportionality.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

30/44

II. That, in the event that the arguments regarding the non-application of the principle of culpability are not accepted, the arguments presented regarding the imposition of sanctions related to art. 51.f) and 32 of the GDPR be taken into account. AFIANZA considers its compliance with the principle of confidentiality (art. 5.1.f) of the GDPR) sufficiently proven, and there are no sufficient legal arguments to determine otherwise, especially considering how this Control Authority has sanctioned in recent years.

III. That the grievance resulting from comparing the economic amount proposed to AFIANZA with that which the AEPD has been imposing on other entities be taken into consideration, especially if a similar case is considered, such as the one presented in section II, where the impact has been 100 times greater than that which AFIANZA could have experienced, and yet the treatment in determining the sanction and the assessment of other elements such as mitigating factors or the non-imposition of other violations has been absolutely negative for AFIANZA. Therefore, this AEPD is requested to quantify the sanctions in accordance with its own resolutions.

IV. That, if the sanction is ultimately deemed appropriate, the publication of the resolution be avoided for two fundamental reasons:

a. Firstly, because linking the facts that will inevitably be recounted in the resolution with AFIANZA makes it quite easy to identify the affected individuals.

b. Since there is no evidence that the information on the USB has been used by the person who committed the theft, it is very possible that they are unaware of the content of the USB. When the resolution is made public, they could become aware of the information it contains and then seek to exploit it in some way that would now indeed cause harm to the affected individuals. This would aggravate the consequences of the breach due to the publication of the resolution without having dissociated the information.

V. That, if the AEPD is obliged to publish the resolution of the sanction, any express reference (...) as well as to the company Afianza Asesores, S.L. be omitted for the same reasons stated in point IV above.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: (...). The USB device is not encrypted nor does it have any other protective measures in place against unauthorized third parties.

SECOND: AFIANZA notifies the security breach to the AEPD on June 30, 2021, and begins actions aimed at communicating to the affected individuals on July 8, 2021.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

31/44

LEGAL GROUNDS

I

Competence and Applicable Regulations

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, in accordance with the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, since AFIANZA carries out, among other processes, the collection, registration, organization, storage, consultation, access, and deletion of personal data of individuals, such as: name, identification number, date of birth, sex, marital status, contact details, image, voice, and data on convictions and criminal offenses, among others.

AFIANZA carries out this activity in its capacity as data controller, as it is the entity that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach due to the theft of an unencrypted USB device (...), containing the previously referenced personal data, which allows unauthorized access to it.

The security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern both the security of processing, the notification of a personal data security breach to the supervisory authority, and the communication to the data subject, respectively.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/44

III

Claims Made

In relation to the claims made regarding the proposed resolution of this sanctioning procedure, the following responses are provided:

1.- Security Breach and Measures Implemented

AFIANZA states that it disagrees with this Agency referencing the Guidelines 01/2021 of the European Data Protection Board (hereinafter the Board) to support its position, understanding that this causes it absolute defenselessness.

In this regard, it is important to recall that AFIANZA, in its written allegations to the Initiation Agreement of this sanctioning procedure, denied that a security breach had occurred, much less that it had affected confidentiality, to which this Agency first proceeded to clearly argue why the conditions for understanding that there was such a confidentiality breach were met, mentioning, secondly, the aforementioned Guidelines of the Board as a reflection of the fact that this European body holds the same interpretation, as it reaches the same conclusion in a basically identical case.

It should be noted that the Board is tasked with ensuring the consistent application of the GDPR (art. 70.1) and that for this purpose, among other specific functions and powers attributed to it, it will examine, on its own initiative, at the request of one of its members or the Commission, any issue related to the application of this Regulation, and will issue guidelines, recommendations, and best practices to promote the consistent application of this Regulation (art. 70.1.e GDPR).

Therefore, when interpreting the GDPR, one must not forget the unquestionable preeminence that this regulation attributes to the guidelines, recommendations, opinions, etc., of the Board.

On the other hand, AFIANZA states that, although the USB was not encrypted, there were other security measures implemented in the processing it carries out, and that not taking them into account implies assuming that it has not complied with any of the obligations inherent to its role as data

controller and that it has not only failed to establish measures but also "facilitates" third parties' access to the information for which it is responsible.

In response, it is reiterated that the infringement attributed is precisely the breach of confidentiality due to the USB lacking any encryption measures or any other measures aimed at preventing unauthorized access to its content (personal data) by unauthorized third parties. As already indicated in the Proposal for Resolution of this sanctioning procedure, in the case of portable electronic storage devices, there is the ability and possibility to protect them through technical security measures that significantly hinder or prevent access to them by third parties, so in this case,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
33/44

In this case, since none of the measures established for the stolen USB existed, it constitutes a violation of confidentiality and, therefore, of Article 5.1 f) of the GDPR, which precisely requires that personal data be processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality").

2.- Violation of Article 32 of the GDPR

AFIANZA claims that, prior to the incident, in compliance with the principle of proactive responsibility, it had conducted its risk analyses and defined its security measures, both technical and organizational (which it describes), measures that go beyond mere encryption, so asserting that there were no security or protection measures in place is contrary to the established facts.

In this regard, it is first noted that it is in relation to the stolen USB that the absence of any type of protection or impediment against access by unauthorized third parties has been indicated.

Secondly, regarding the allegation of the violation of Article 32 of the GDPR, as already indicated in the Proposal for Resolution in response to the same allegation, which is transcribed in point 2 of the Eighth Background Fact and to which we refer in order to avoid unnecessary repetitions, it can be deduced from the events that many of the security measures implemented— as recognized by the entity—were not being observed and were necessary for adequate protection and a level of security appropriate to the risk of processing, and that this allowed for the theft of the USB and the breach of security of personal data, which also affected their confidentiality.

It is reiterated once again that Article 32 of the GDPR is violated both if the data controller does not adopt appropriate technical and organizational measures to ensure the security of personal data, and if, once established, these measures are not observed. It is precisely this lack of observance that constitutes the violation indicated in Article 73 of the LOPDGDD, which states that, according to what is established in Article 83.4 of Regulation (EU) 2016/679, violations that constitute a substantial breach of the articles mentioned therein are considered serious and will be subject to a two-year statute of limitations, particularly including the following:

g) The breach, as a consequence of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679." (...)

3.- Violation of Article 5.1f.

AFIANZA states that it has not violated this provision since, after the corresponding risk analysis, it had implemented the necessary technical and organizational measures to ensure the integrity, availability, and confidentiality of personal data, and that a different matter is that on a specific day, at a specific time, and due to specific circumstances, there was a lack of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
34/44

the applicability of some of the implemented security measures, but this is very different from asserting that none existed, as well as from assuming that the principle of confidentiality has been violated. In this regard, it is appropriate to reiterate all that has already been argued concerning the lack of observance of the implemented security measures and that this resulted in a security breach affecting the confidentiality of the data stored on the USB without any protection against unlawful access, constituting a violation of Article 5.1 f. Therefore, we refer to everything addressed in the resolution proposal, which is reproduced in the Eighth Background of the present resolution.

On the other hand, AFIANZA argues that everything that occurred was a consequence of criminal activity and that this does not imply a failure to comply with measures, since the fact that a third party has bypassed such measures does not, per se, imply a breach of obligation, as the data controller is subject to an obligation of means, not an obligation of result.

In this regard, it should be noted that the obligation of means referred to was not being fulfilled, as the security measures indicated by the entity, both technical and organizational, were not being observed, which allowed the incident to occur without any obstacles or measures that needed to be resolved or violated.

4.- Other sanctioning procedures processed by this Agency.

AFIANZA refers to a series of Resolutions from sanctioning procedures previously processed by this Agency in order to allege disproportionality in the imposed sanctions, including differences in the attribution of violations regarding what it understands to be the same facts or significant similarities.

In this regard, it should be noted that the resolutions analyzed by AFIANZA, while they may have similarities, also have differences with the specific circumstances of the present case. Thus, there are differences regarding the number of individuals affected by the breach of confidentiality (in many cases, only one person); regarding the processing of personal data carried out by the sanctioned party (whether it is their main activity, whether it is ancillary, whether it is minimal, whether greater diligence is required according to the sector, etc.); regarding the category of affected data; regarding the number of affected personal data (in some cases, only the email or a few more data); the timing of the events concerning the time that the GDPR had been applicable (in many cases, only months, which is different from nearly 3 years). In this sense, it should not be forgotten that when determining the sanctions to be imposed, the specific circumstances of the case must be taken into account.

On the other hand, AFIANZA only brings up resolutions from cases that were processed at the beginning of the application of the GDPR. However, it has not mentioned other later cases that could be more similar to its situation regarding the attributed violations and the amount of the sanctions—without forgetting, it is emphasized, that the specific circumstances of the case must be considered—and that, furthermore, it should also be taken into account that they have been processed once there are more clarifications and...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/44

interpretations made both by the Control Authorities and by the European Data Protection Committee, as well as judgments from the courts that are being issued, thus forming jurisprudence on the matter. (...)

On the other hand, it should not be forgotten that AFIANZA is a company dedicated to legal advisory services, with its activity involving constant and abundant handling of personal data—among which, it is emphasized, are those related to criminal offenses and sanctions. Both circumstances are relevant when assessing the degree of diligence, particularly weighing the professionalism or lack thereof of the subject, which means that AFIANZA must exercise greater rigor and exquisite care to comply with the legal provisions in this regard.

Therefore, all these circumstances are what have been taken into account and have conditioned the amount of the imposed sanctions.

5.- Aggravating Circumstances

AFIANZA again states that it does not agree with the aggravating circumstances considered when

determining the calculation of the sanction. Thus:

- Art. 83.2b) GDPR. Intentionality or negligence in the infringement

AFIANZA reiterates that negligent behavior cannot be appreciated, and furthermore claims that it is unaware of the reasons and arguments for which the aggravating circumstances are applied, as this Agency has not specified which actions and omissions are attributed to these aggravating circumstances.

In response, it is noted that both in the Initiation Agreement and in the Resolution Proposal, the reasons and arguments for considering the aggravating circumstances taken into account when determining the amount of the sanction are clearly indicated. Therefore, reference should be made to everything stated regarding the failure to observe the technical and organizational measures that were not being followed at the time of the incident, which clearly demonstrates negligence on the part of AFIANZA.

Additionally, reference should be made to what is indicated in the Resolution Proposal as a response to the allegations made against the Initiation Agreement, which is transcribed in the Eighth Background of Facts, as well as to Legal Grounds VI and IX of this resolution.

- Art. 83.2 g) GDPR. The categories of personal data affected.

Regarding this aggravating circumstance, AFIANZA states that it is not applicable since the data had already been made publicly available prior to the day of the theft, as they refer to a well-known criminal case, citing the Judgment of the Court of Justice of the European Union of November 24, 2011, which implies a lesser impact on the rights of the affected individuals, which should be taken into account.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/44

(...)

Therefore, although information regarding some of the investigated individuals has been published in the media, it is not appropriate to accept that all personal data related to all affected individuals was published prior to the incident, in addition to the fact that no evidence has been provided in this regard.

6.- Mitigating Circumstances

AFIANZA reiterates a series of circumstances that it believes should have been considered as mitigating factors.

In this regard, it is necessary to recall that many of them cannot be considered as such, as indicated in the Proposal for Resolution of this sanctioning procedure in response to this same allegation, which is transcribed in the Eighth Background of this resolution and to which reference should be made in order to avoid unnecessary repetitions.

However, regarding the consideration of the mitigating factor of Article 83.2.h (the manner in which the supervisory authority became aware of the infringement, particularly whether the data controller or processor notified the infringement and, if so, to what extent), AFIANZA argues that as soon as it became aware of the incident, it notified this Agency and also identified the affected individuals and contacted them to inform them of what happened, which demonstrates clear proactivity. It should be clarified—besides the fact that this does not constitute a mitigating circumstance, as it is a legal obligation—that several issues arise:

Firstly, as already indicated in the proposal for resolution, the notification period to this Agency in the event of a personal data security breach is a mandatory period: without undue delay and, if possible, no later than 72 hours after becoming aware of it. Therefore, this is the maximum period allowed for making the notification. Furthermore, in line with the fact that it is a mandatory period, Article 74 m) of the LOPDGDD classifies as a minor infringement the incomplete, late, or defective notification to the data protection authority of information related to a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679, an infringement that has not been attributed to AFIANZA due to the expiration of the one-year limitation period at the time the Initiation Agreement was issued, in accordance with the aforementioned Article 74.

The only circumstance that allows for not notifying without undue delay and, if applicable, no later than 72 hours, is the lack of knowledge or any other justified reason, which must be substantiated. In the case at hand, practically from the moment of the theft or, at most, the following day (when the police report of the theft is filed, which already indicates the theft of the USB and its contents), there is already knowledge of the confidentiality breach suffered, from which the indicated period begins to be computed. However, the notification was not made until 13 days later, which is not acceptable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/44

as reasons for the delay argued by AFIANZA, as none of them justify such a delay.

Secondly, it is noted that Article 34 requires that when it is likely that the breach of personal data security poses a high risk to the rights and freedoms of natural persons, the data controller shall communicate it to the data subject without undue delay. It should not be forgotten that the purpose of the notifications and communications required in Articles 33 and 34 of the GDPR is to reduce risks to the rights and freedoms of affected individuals when a security breach may pose a risk to them, in this case, a high risk. Therefore, the delay in such notification prevented this Agency from analyzing the situation with the utmost urgency and, as has occurred, negatively assessing AFIANZA's decision not to communicate it to the affected parties—disregarding the seriousness of the possible adverse effects—resulting in this delay preventing them from taking the measures and reactions they deem necessary to safeguard their rights and freedoms as soon as possible.

7.- Non-concurrence of the principle of culpability

AFIANZA points out that objective or faultless liability does not apply in the administrative sanctioning sphere, whereby the possibility of imposing sanctions for mere results is excluded, without proving a minimum level of culpability, even in the case of mere negligence. In this regard, it considers that it has not acted culpably, being evident the absence of unlawfulness and culpability in its conduct, as the incident was the result of a criminal act by a third party, and thus, a results-based obligation cannot be demanded, but rather an obligation of means.

In response to this, it should be noted that this allegation has already been addressed in the Proposal for Resolution of the current sanctioning procedure, and thus reference should be made to it.

However, it should be clarified again that AFIANZA is not considered responsible for the result, but for a loss of confidentiality linked to the non-observance of a series of implemented security measures and, ultimately, due to a lack of diligence on the part of the entity. In this sense, the Judgment of the Supreme Court of February 15, 2022 (Rec. 7359/2020) indicates that “It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, so that it will also be liable for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case.”

This lack of diligence by AFIANZA, as the data controller, in observing or verifying the adequacy of the appropriate security measures is what constitutes the element of culpability.

Finally, regarding the assertion that AFIANZA cannot be blamed for the criminal acts committed by third parties, it should be noted that this Agency does not extend the entity's responsibility beyond its obligations as the data controller.

8.- Other issues raised

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/44

Finally, AFIANZA requests that the resolution not be published if the sanction ultimately proceeds, arguing that this would facilitate the identification of the individuals affected by the breach, as well as incentivize the person who stole the USB to access it and potentially exploit the information to the detriment of those affected.

In this regard, it is indicated that the present resolution does not fall within the cases contemplated in Article 50 of the LOPDGDD where publication is mandatory.

For all the reasons stated above, the allegations made are rejected.

IV

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

The principle of data security requires the application of appropriate technical or organizational measures that ensure the security of personal data and prevent its alteration, loss, unauthorized or unlawful processing or access. In this sense, security measures are key to guaranteeing the fundamental right to data protection. The existence of the fundamental right to data protection is not possible if confidentiality, integrity, and availability of the data are not guaranteed.

Thus, the security and confidentiality of personal data are considered essential to prevent affected individuals from suffering negative effects. Therefore, they must be processed in a manner that ensures adequate security and confidentiality of personal data, especially to prevent unauthorized access or use of such data and the equipment or system used in the processing.

Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, with the aim of, under the principle of proactive responsibility, complying with and being able to demonstrate compliance, while respecting the fundamental right to data protection.

In the present case, the principle of confidentiality has been violated as it is established that AFIANZA suffered the theft of a USB device containing unencrypted personal data (...).

The fact that the device was not encrypted, i.e., without any measure or system to prevent unauthorized access and that it was stolen by a third party, constitutes a violation of the obligation to guarantee the confidentiality of the data, in addition to reflecting the storage of personal data on mobile devices without any protection of that information—especially considering the type of personal data processed—which reveals a failure to comply with the obligation to process them in such a way as to ensure adequate security of personal data, including protection against unauthorized or unlawful processing.

Therefore, in accordance with the available evidence, it is considered that the known facts could constitute an infringement attributable to AFIANZA for violating Article 5.1.f) of the GDPR.

V

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall be subject to a limitation period of three years, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5

of Regulation (EU) 2016/679. (...)"

VI

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the available evidence, it is considered that the infringement in question is very serious for the purposes of the GDPR and that it is appropriate to scale the sanction to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/44

impose according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2.b) GDPR. Intent or negligence in the infringement: While it is considered that there was no intent on the part of AFIANZA, there is evidence of negligence in the compliance and observance of the technical and organizational measures to ensure the necessary security for the protection of personal data, specifically to guarantee their confidentiality, since personal data was stored on a removable device without being encrypted, which reflects negligence in observing basic and simple measures, especially considering that these are data related to convictions and criminal offenses. It is worth recalling, in this regard, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, states that "...the Supreme Court has understood that there is recklessness whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard.

- Article 83.2.g) GDPR. Categories of personal data affected by the infringement: Personal data related to offenses and criminal sanctions have been affected, (...).

Considering the factors presented, the assessment of the amount of the fine for the infringement of Article 5.1.f) of the GDPR attributed is €90,000 (ninety thousand euros).

VII

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/44

d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, particularly as a consequence of the accidental or unlawful

destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved under Article 40 or to a certification mechanism approved under Article 42 may serve as a means to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.

The principle of data security requires the application of appropriate technical or organizational measures in the processing of personal data to protect such data against unauthorized or unlawful access, use, modification, disclosure, loss, destruction, or accidental or unlawful damage. In this regard, security measures are key to ensuring the fundamental right to data protection. The existence of the fundamental right to data protection is not possible if the confidentiality, integrity, and availability of such data cannot be guaranteed.

It should not be forgotten that, in accordance with Article 32.1 of the GDPR, the technical and organizational measures to be applied to ensure an adequate level of security relative to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons.

In this regard, it should be noted that the activity of AFIANZA involves the processing of data related to convictions and criminal offenses, including personal data of individuals who testify.

In this case, AFIANZA suffered the theft of a USB device containing personal data (...), resulting in a security breach consisting of a breach of confidentiality.

As detailed in paragraph 2 of the Eighth Recital of Facts, from the events that occurred and the analysis of the documentation in the file, it is inferred that an unauthorized person accessed the entity's premises without the security measures in place functioning or being observed, and the theft of an unencrypted USB device (or without any other protective measure), containing numerous personal data related to a criminal judicial investigation procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/44

Therefore, this constitutes a breach of Article 32, as it is infringed both if the controller does not adopt the appropriate technical and organizational measures to ensure the security of personal data, and if, once established, those measures are not observed.

From the above, it is deduced that there is a lack of due diligence both in complying with the established security measures and in supervising or verifying their observance and their suitability or effectiveness.

In accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to AFIANZA for violation of Article 32 of the GDPR.

VIII

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringement classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, whichever is higher:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

“Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall be subject to a limitation period of two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

g) The breach, as a result of a lack of due diligence in the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.” (...)

IX

Sanction for the infringement of Article 32 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/44

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the available evidence, it is considered that the infringement in question is serious for the purposes of the GDPR and that the sanction to be imposed should be graduated according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2.b) GDPR. Intentionality or negligence in the infringement: While it is considered that there was no intentionality on the part of AFIANZA, negligence can be observed in the compliance and observance of the technical and organizational measures to ensure the necessary security for the protection of personal data, since neither the existing logical nor physical access controls functioned due to non-compliance with them, as well as the fact that personal data was stored on a removable device without being encrypted, which again reflects negligence in the observance of such measures, especially considering that these are data related to convictions and criminal offenses. It is worth recalling, in this regard, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that “...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard.

- Article 83.2.g) GDPR. Categories of personal data affected by the infringement: Personal data related to offenses and criminal sanctions have been affected, (...).

Considering the factors presented, the assessment of the amount of the fine for the infringement of Article 32 of the GDPR attributed is 55,000 euros (fifty-five thousand euros).

Therefore, in accordance with the applicable legislation and having evaluated the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on AFIANZA ASESORES, S.L, with NIF B83117804, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, a fine of NINETY THOUSAND EUROS (90,000 euros).

SECOND: TO IMPOSE on AFIANZA ASESORES, S.L, with NIF B83117804, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of FIFTY-FIVE THOUSAND EUROS (55,000 euros).

THIRD: TO NOTIFY this resolution to AFIANZA ASESORES, S.L.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
44/44

FOURTH: To inform the sanctioned party that they must comply with the imposed sanction once this resolution becomes executive, in accordance with the provisions of art. 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in art. 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to art. 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receiving the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-181022
Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es